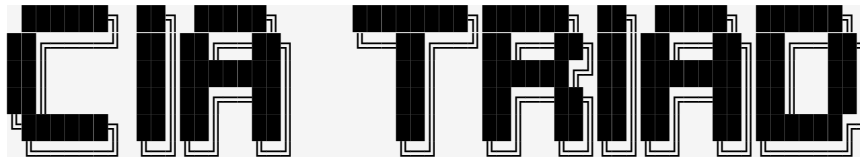


README — KIT GQM+PRAGMATIC CIA TRIAD

Guía Completa de Instalación, Uso e Integración del Kit de Métricas

CIA Triad Metrics Framework — España 2025 | v2.0



GQM + PRAGMATIC — Kit de Métricas de Ciberseguridad para España
Versión 2.0 | Abril 2025

¿QUÉ ES ESTE KIT?

El **CIA Triad GQM+PRAGMATIC Kit** es un sistema completo de métricas de ciberseguridad diseñado para organizaciones españolas que necesitan medir, gestionar y comunicar su nivel de madurez en los pilares de **Confidencialidad, Integridad y Disponibilidad** (CIA) — con extensiones a Autenticidad y Trazabilidad (CIANA).

El kit integra dos metodologías de referencia internacional:

- GQM (Goal-Question-Metric): Garantiza que cada métrica responde a una pregunta específica vinculada a un objetivo nacional estratégico. Desarrollado en NASA (Basili & Weiss, 1984), codificado en ISO/IEC 15939.
- PRAGMATIC: Evalúa la calidad de cada métrica bajo 9 criterios (Predictivo, Relevante, Accionable, Genuino, Measurable, Accurate, Timely, Independiente, Cost-effective). Formalizado por Brothby y Hinson (2013).

GQM (Goal-Question-Metric): Garantiza que cada métrica responde a una pregunta específica vinculada a un objetivo nacional estratégico. Desarrollado en NASA (Basili & Weiss, 1984), codificado en ISO/IEC 15939.

PRAGMATIC: Evalúa la calidad de cada métrica bajo 9 criterios (Predictivo, Relevante, Accionable, Genuino, Measurable, Accurate, Timely, Independiente, Cost-effective). Formalizado por Brothby y Hinson (2013).

El resultado es un sistema de **22 indicadores primarios y 45+ sub-métricas** con trazabilidad completa desde los marcos regulatorios (ENS, NIS2, DORA, RGPD, EU AI Act, eIDAS 2, NIST PQC) hasta los datos técnicos operacionales.

ÁRBOL DE FICHEROS DEL KIT

QGM-PRAGMATIC-CIA-TRIAD-KIT-v2025/

-  GQM-marco-integrativo.md
 - Marco completo QGM+PRAGMATIC: 6 objetivos nacionales, 45+ métricas con fórmulas, umbrales y fuentes de datos. Incluye fórmula IGM-CIA y pesos sectoriales.
-  GQM-matriz-PRAGMATIC.md
 - Calificación individual de los 22 indicadores bajo los 9 criterios PRAGMATIC (0-3 cada uno). Ranking final, análisis de patrones y recomendaciones por nivel de madurez.
-  GQM-narrativa-explicativa.md
 - El porqué epistemológico del marco: desde el problema del indicador huérfano hasta las implicaciones para la política cibernética española. Lectura obligatoria para investigadores y estrategas.
-  GQM-mapeo-normativo.md
 - Tabla maestra: cada sub-métrica → objetivo QGM → marco normativo principal → artículo específico → marcos secundarios → obligatoriedad → plazo. 60+ filas.
-  GQM-plantilla-excel-IGM-ROI.md
 - Especificación completa de 9 hojas Excel: entrada de datos, normalización automática, cálculo IGM-CIA, escenarios FAIR, ALE/ROSI, dashboard ejecutivo y Gantt de roadmap.
-  GQM-reporte-ejecutivo-pptx.md
 - 18 diapositivas especificadas para Consejo de Administración: portada, resumen ejecutivo, semáforos por pilar, FAIR, benchmarks, plan de acción y roadmap a 18 meses.
-  GQM-README-kit.md (este archivo)
 - Guía de uso, instalación, integración y FAQ.

GUÍA DE IMPLEMENTACIÓN EN 4 FASES

Fase 0 — Onboarding del Kit (Días 1-3)

Paso 1: Lectura del Marco

- Leer GQM-marco-integrativo.md completo
- Identificar los 6 objetivos nacionales relevantes para su sector
- Seleccionar el perfil de pesos sectoriales (Tabla §4.1)

Paso 2: Revisión del Mapeo Normativo

- Abrir GQM-mapeo-normativo.md
- Filtrar por "● Obligatorio" y "⚡ Inmediato"
- Esta lista es la agenda de la primera reunión del equipo

Paso 3: Comprensión PRAGMATIC

- Revisar GQM-matriz-PRAGMATIC.md para los indicadores de su sector
- Identificar los de Clase A: son la prioridad de implementación
- Aceptar las limitaciones de los indicadores Clase B/C: son honestas

Fase 1 — Implementación de la Plantilla Excel (Días 4-15)

Paso 4: Configuración del libro Excel

- Implementar el libro Excel según GQM-plantilla-excel-IGM-ROI.md
- Crear las 9 hojas en el orden indicado
- Introducir fórmulas de normalización en 02_CODIFICACION
- Configurar validaciones de datos en 01_DATOS_RAW

Paso 5: Primera toma de datos

- Identificar las fuentes de datos disponibles para cada métrica
- Introducir valores actuales en la columna H de 01_DATOS_RAW
- Para métricas sin datos disponibles: introducir N/A y documentar la razón y el plan para obtener el dato (columna Notas)
- Calcular IGM-CIA inicial: este es el punto de partida

Paso 6: Calibración de escenarios FAIR

- Seleccionar los 3-5 escenarios de riesgo más relevantes para su sector
- Ajustar ARO y SLE a la realidad de su organización (los valores pre-cargados son referencias globales)
- Calcular ROSI de las inversiones de control prioritarias

Fase 2 — Preparación del Primer Reporte Ejecutivo (Días 15-30)

Paso 7: Adaptación de la plantilla PowerPoint

- Implementar las 18 diapositivas según GQM-reporte-ejecutivo-pptx.md
- Sustituir los valores de ejemplo [X,X] por los datos reales del Excel
- Seleccionar las 5 hallazgos críticos más relevantes (Diap. 12)
- Construir el roadmap con los proyectos específicos de su organización

Paso 8: Validación del primer ciclo

- Revisar que los umbrales críticos/objetivo son realistas para su contexto
- Ajustar pesos sectoriales si el perfil pre-definido no se ajusta
- Documentar fuentes de datos para reproducibilidad del cálculo

Fase 3 — Operación Regular (Ciclo mensual/trimestral)

Paso 9: Rutina de actualización de datos

Semanal:

- Actualizar M-I02a-d (TMPVC) del vulnerability scanner
- Actualizar M-A06a (Edge Patch Latency)
- Revisar M-I02c (CVE > 30 días sin parche)

Mensual:

- Actualizar M-C01a (MFA Coverage) del IAM
- Actualizar M-A04a-c (Uptime) del monitoring
- Actualizar M-A01a/M-A02a (MTTD/MTTR) del ITSM
- Revisar dashboard 07_DASHBOARD en Excel
- Macro: ActualizarFechas()

Trimestral:

- Actualizar M-C02b (Access Review), M-AT02b (Phishing Click Rate)
- Comparar IGM-CIA actual vs. trimestre anterior (hoja 04_BENCHMARK)
- Actualizar sección de tendencias en la presentación PowerPoint
- Presentar al Comité de Seguridad o Comité de Auditoría

Semestral:

- Revisar umbrales y ajustar si el contexto ha cambiado
- Actualizar escenarios FAIR con datos de incidentes reales
- Ejecutar Macro: NuevoPeriodo() para archivar periodo anterior
- Revisar mapeo normativo ante cambios regulatorios

Paso 10: Gobernanza del proceso de medición

- Designar propietario de cada métrica (columna Responsable en 08_ROADMAP)
- Establecer SLA de actualización por frecuencia
- Crear comité de revisión trimestral de umbrales
- Documentar el proceso en el SGSI (ISO 27001 A.5.25 o equivalente)

TABLA DE COMPATIBILIDAD POR PLATAFORMA

Herramientas de origen de datos

Métrica	Herramienta de origen	Plataformas compatibles	Extracción
MFA Coverage	IAM/IdP	Azure AD, Okta, Ping Identity, Google Workspace	API nativa / Informe > CSV
Orphan Accounts	IAM + HRMS	SCIM sync (Workday, SAP HR) – IAM	Informe desincronización HR-IAM
PAM Coverage	PAM platform	CyberArk, BeyondTrust, Delinea, Wallix	Consola > Informe cuentas gestionadas
TMPVC	Vulnerability Scanner	Tenable.io, Qualys, Rapid7, OpenVAS	Export CSV/JSON por fecha publicación CVE
FIM Coverage	FIM tool	Tripwire, Wazuh, AIDE, Qualys FIM	Consola > Assets con FIM activo
MTTD/MTTR	ITSM/SOAR	ServiceNow, Jira Service Mgmt, IBM QRadar SOAR	Informe tiempo de resolución
Uptime	Monitoring	Prometheus, Datadog, Nagios, Zabbix, New Relic	Dashboard SLA > Export
Log Centralization	SIEM	Splunk, Microsoft Sentinel, IBM QRadar, LogScale	Informe fuentes de logs activas
Phishing Click Rate	Awareness platform	KnowBe4, Proofpoint SAT, Cofense, Mimecast	Informe simulacros > Export CSV
DLP Coverage	DLP	Microsoft Purview, Forcepoint, Symantec DLP	Informe canales cubiertos > Export
Shadow AI	CASB	Microsoft Defender for Cloud Apps, Netskope, Palo Alto SASE	Informe apps IA detectadas
Backup Verification	Backup platform	Veeam, Veritas, Commvault, Azure Backup	Log restauraciones exitosas
Edge Patch Latency	Patch mgmt	WSUS, SCCM, Jamf, Ivanti	Informe parcheo por tipo dispositivo
ZT Maturity	Assessment	CISA ZT Assessment Tool (gratuito)	Resultado manual escala 0-3
PQC Inventory	Crypto scanner	Cryptosense, IBM Guardium, Venafi	Informe algoritmos detectados
PKI Health	PKI mgmt	Venafi TLS Protect, Sectigo, Let's Encrypt API	Informe certificados por estado

Plataformas de encuesta compatibles para recolección de datos cualitativos

Plataforma	Tipo	Compatibilidad con el Kit	Notas
LimeSurvey	Open source / self-hosted	★★★★★	Exporta CSV directamente compatible con 01_DATOS_RAW
Microsoft Forms	SaaS / M365	★★★★★	Exporta Excel; requiere mapeo de columnas
Google Forms	SaaS / Google	★★★★★	Exporta Google Sheets; compatible con Sheets version
SurveyMonkey	SaaS	★★★★★	Requiere plan Business+ para export avanzado
Qualtrics	Enterprise	★★★★★	Integración API para automatización
Typeform	SaaS	★★★★★	Buena UX; export básico en planes gratuitos
KoBoToolbox	Open source / ONG	★★★★★	Recomendado para encuestas a múltiples organizaciones

GLOSARIO DE TÉRMINOS

Término	Definición	Marco de referencia
ALE	Annual Loss Expectancy — Pérdida esperada anual = ARO × SLE	FAIR / NIST SP 800-30
ARO	Annualized Rate of Occurrence — Frecuencia anual de un evento de riesgo	FAIR
CIA Triad	Confidentiality, Integrity, Availability — El modelo de tres pilares de la seguridad	ISO 27001, NIST
CIANA	Extensión del CIA con No Repudio y Autenticidad	ENS España, ISO 27001
CVSS	Common Vulnerability Scoring System — Sistema de puntuación de vulnerabilidades v4.0	FIRST.org
EPSS	Exploit Prediction Scoring System — Probabilidad de explotación de CVE	FIRST.org v3
FAIR	Factor Analysis of Information Risk — Metodología de cuantificación de riesgo	Open FAIR
FIM	File Integrity Monitoring — Monitorización de integridad de ficheros	NIST SP 800-53 SI-7
GQM	Goal-Question-Metric — Marco de trazabilidad de métricas desde objetivos	ISO/IEC 15939
IAM	Identity and Access Management — Gestión de identidades y accesos	ISO 27001 A.8.5
IGA	Identity Governance and Administration — Gobierno de identidades y accesos	Gartner
IGM-CIA	Índice Global de Madurez CIA — Score compuesto 0-5 de este framework	Original
KEV	Known Exploited Vulnerabilities — Catálogo CISA de vulnerabilidades explotadas activamente	CISA
MTTC	Mean Time to Contain — Tiempo medio de contención de un incidente	ISO 27035

MTTD	Mean Time to Detect — Tiempo medio de detección de un incidente	NIST CSF 2.0 DE
MTTR	Mean Time to Recover/Resolve — Tiempo medio de recuperación/resolución	ISO 27035
PAM	Privileged Access Management — Gestión de accesos privilegiados	CyberArk, BeyondTrust
PQC	Post-Quantum Cryptography — Criptografía resistente a computación cuántica	NIST FIPS 203-205
PRAGMATIC	Marco de evaluación de calidad de métricas (9 criterios)	Brotby & Hinson (2013)
ROSI	Return on Security Investment — Retorno sobre inversión en seguridad	Gordon & Loeb model
RPO	Recovery Point Objective — Pérdida máxima tolerable de datos	ISO 22301
RTO	Recovery Time Objective — Tiempo máximo tolerable de inactividad	ISO 22301
SBOM	Software Bill of Materials — Inventario de componentes software	CycloneDX / SPDX
SLE	Single Loss Expectancy — Impacto financiero de un único evento de riesgo	FAIR
TMPVC	Tiempo Mediano de Parcheo de Vulnerabilidades Críticas	Original / NIST SP 800-53 RA-5
ZT / ZTA	Zero Trust / Zero Trust Architecture — Paradigma "nunca confiar, siempre verificar"	NIST SP 1800-35

PREGUNTAS FRECUENTES (FAQ)

P: ¿Necesito implementar las 45 sub-métricas para empezar?

R: No. El kit está diseñado para implementación por fases. Para el primer mes, con 5-6 indicadores de Clase A (TMPVC, MFA, Uptime, MTTD, Phishing Click Rate) ya tendrá un IGM-CIA significativo y accionable. La cobertura completa es el objetivo a 18 meses.

P: Los umbrales propuestos son muy ambiciosos para nuestra PYME. ¿Puedo ajustarlos?

R: Los umbrales son recomendaciones basadas en la evidencia empírica 2025 (Verizon, IBM, ENISA). Puede ajustarlos a su contexto, pero documente el ajuste y la justificación. Un umbral objetivo de TMPVC críticas de 30 días en lugar de 7 días tiene implicaciones de exposición reales; simplemente, sea consciente de ellas al informar al Consejo.

P: ¿Cómo integro este kit con nuestra certificación ISO 27001 existente?

R: El kit GQM+PRAGMATIC complementa sin reemplazar ISO 27001. Los indicadores corresponden directamente a controles de ISO 27001:2022 (documentados en el mapeo normativo). Puede usar el IGM-CIA como el mecanismo de "monitorización y medición" requerido por ISO 27001 §9.1 y el FAIR ROSI como base para §6.1.2 (evaluación de riesgos).

P: ¿El IGM-CIA de 3,1 de nuestra organización es bueno o malo?

R: Depende del contexto. El 61% de empresas españolas están en nivel "Formativo" (IGM equivalente ~1,5-2,0 según Cisco CRI 2025). Un IGM-CIA de 3,1 (nivel "Definido") sitúa a su organización significativamente por encima de la media española. En relación al objetivo NIS2 mínimo (~3,0), está en el umbral. La referencia más relevante es el benchmark de su sector específico.

P: ¿Cómo gestiono las métricas para las que no tengo datos (N/A)?

R: Documente el gap en la columna Notas de 01_DATOS_RAW con: (1) razón por la que el dato no está disponible, (2) herramienta o proceso necesario para obtenerlo, (3) plazo estimado. En el cálculo del IGM-CIA, los N/A reciben Score 0 — esto es correcto: si no puede medir un control, el nivel de madurez en ese área es efectivamente cero desde la perspectiva de la gestión.

P: ¿Cada cuánto debo hacer la evaluación PRAGMATIC de los indicadores?

R: La evaluación PRAGMATIC de los indicadores en sí (la calificación de calidad) no cambia frecuentemente — está condicionada por cambios en la tecnología de medición o en el contexto normativo. Revísela semestralmente y ante cambios normativos significativos (nueva transposición NIS2, publicación de nuevos estándares NIST, etc.). Los valores de las métricas sí se actualizan con la frecuencia indicada en el marco.

P: ¿Puedo compartir el IGM-CIA con el regulador (INCIBE, CCN-CERT, BdE)?

R: El framework no está estandarizado oficialmente a nivel regulatorio español (aún). Sin embargo, los indicadores individuales y sus valores son directamente relevantes para los cuestionarios de autoevaluación NIS2 y los formularios de notificación de incidentes. El IGM-CIA puede usarse como evidencia de madurez en auditorías de cumplimiento, pero no reemplaza una auditoría formal según ENS u otros marcos certificables.

P: ¿Existe una versión del kit en inglés para organizaciones multinacionales?

R: El presente kit está diseñado para el contexto normativo español y redactado en español. El marco GQM+PRAGMATIC es internacionalmente reconocido y los indicadores son directamente aplicables en

cualquier país. La adaptación a contextos normativos de otros países requeriría ajustar el mapeo normativo (sustituir ENS por NIS2 nativa, DORA, o equivalentes nacionales) y los benchmarks de referencia.

P: ¿Cómo cito este kit en publicaciones académicas?

R: Este kit es un instrumento de práctica profesional basado en metodologías académicas establecidas. Para citar las metodologías subyacentes: Basili, V.R. & Weiss, D.M. (1984). "A Methodology for Collecting Valid Software Engineering Data". IEEE TSE, 10(6). / Brothby, W.K. & Hinson, G. (2013). "PRAGMATIC Security Metrics". CRC Press. / ISO/IEC 15939:2017. Software and systems engineering — Measurement process.

CONTROL DE VERSIONES Y ACTUALIZACIONES

Versión	Fecha	Cambios principales
1.0	Ene 2025	Marco inicial: 18 indicadores, 6 objetivos GQM
1.5	Mar 2025	Adición extensiones CIANA (AT-01 a AT-03); NIST PQC
2.0	Abr 2025	Integración completa PRAGMATIC; 22 indicadores; 45+ sub-métricas; FAIR model; EU AI Act; eIDAS 2
2.1 (planned)	Jul 2025	Post-transposición NIS2 España (LCGC); actualización umbrales con ENISA NIS Investments 2025
3.0 (planned)	Ene 2026	Integración EU CRA (SBOM obligatorio); actualización NIST CSF 2.1 si publicado; benchmark post-DORA primer año

LICENCIA Y ATRIBUCIÓN

Este kit es un instrumento de práctica profesional de libre uso para organizaciones españolas e hispanohablantes en el contexto de su programa de ciberseguridad.

Uso permitido:

- ✓ Uso interno en organizaciones para su programa de métricas
- ✓ Adaptación y personalización al contexto organizacional
- ✓ Uso en consultoría como base metodológica (con atribución)
- ✓ Referencia en publicaciones académicas (con cita adecuada)
- ✓ Compartir con reguladores y auditores como evidencia de madurez

Uso no permitido sin autorización explícita:

- ✗ Distribución comercial sin atribución
- ✗ Presentación como marco propietario sin reconocimiento de fuentes
- ✗ Modificación de los indicadores PRAGMATIC manteniendo la numeración original sin documentar los cambios

Atribución requerida:

"Basado en el CIA Triad GQM+PRAGMATIC Framework v2025.
Metodologías: GQM (Basili & Weiss, 1984 / ISO 15939) +
PRAGMATIC (Brotby & Hinson, 2013 / NIST SP 800-55)."

SOPORTE Y RECURSOS ADICIONALES

Documentación normativa de referencia (acceso gratuito)

Documento	URL
ENS RD 311/2022	https://www.boe.es/buscar/act.php?id=BOE-A-2022-7191
CISA ZT Assessment Tool	https://www.cisa.gov/zero-trust-maturity-model
CISA KEV Catalog	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
NIST CSF 2.0	https://csrc.nist.gov/pubs/cswp/29/final
NIST PQC Standards	https://www.nist.gov/pqc/crypto
ENISA Threat Landscape 2025	https://www.enisa.europa.eu/publications
INCIBE Estadísticas 2025	https://www.incibe.es/incibe-cert/publicaciones
NIS2 Texto oficial	https://eur-lex.europa.eu/legal-content/ES/TXT/?uri=CELEX:32022L2555
DORA Texto oficial	https://eur-lex.europa.eu/legal-content/ES/TXT/?uri=CELEX:32022R2554
EU AI Act	https://eur-lex.europa.eu/legal-content/ES/TXT/?uri=CELEX:32024R1689
eIDAS 2	https://eur-lex.europa.eu/legal-content/ES/TXT/?uri=CELEX:32024R1183
EPSS API	https://api.first.org/data/v1/epss
FAIR Institute	https://www.fairinstitute.org

CIA Triad GQM+PRAGMATIC Kit v2.0 | Abril 2025

"La diferencia entre una organización que mide su ciberseguridad y una que no la mide es la misma que existe entre un piloto con instrumentos y uno que vuela por instinto.

Ambos pueden llegar a su destino en días despejados.

Solo uno de los dos tiene posibilidades reales cuando llega la tormenta."